

AWS Services Security Reference

53 Essential Services — Security Architect Perspective

Covers: Identity · Security · Compute · Serverless · Containers · Networking · Storage · Database
Messaging · Monitoring · Governance · DevOps · Analytics · AI & ML · Agentic AI

Each entry: Key Functionality · Summary · Business Need · Security Impact · Security Configuration

Prepared for: Security Architect / Cloud Security Engineer Interview Prep | 2025

Contents

IDENTITY	
01	AWS IAM
02	AWS IAM Identity Center
03	AWS Organizations
04	AWS STS
SECURITY	
05	AWS GuardDuty
06	AWS Security Hub
07	AWS CloudTrail
08	AWS KMS
09	AWS WAF
10	AWS Shield
11	AWS Secrets Manager
12	AWS Certificate Manager
COMPUTE	
13	Amazon EC2
SERVERLESS	
14	AWS Lambda
CONTAINERS	
15	Amazon ECS
16	Amazon EKS
17	AWS Fargate
NETWORKING	
18	Amazon VPC
19	AWS PrivateLink
20	Amazon Route 53
21	AWS CloudFront
22	AWS Direct Connect
STORAGE	
23	Amazon S3
24	Amazon EBS

25	Amazon EFS
26	AWS Backup
DATABASE	
27	Amazon RDS
28	Amazon DynamoDB
29	Amazon ElastiCache
30	Amazon Aurora
MESSAGING	
31	Amazon SQS
32	Amazon SNS
33	Amazon EventBridge
MONITORING	
34	Amazon CloudWatch
35	AWS Config
36	AWS CloudWatch Synthetics
37	AWS X-Ray
GOVERNANCE	
38	AWS IAM Access Analyzer
39	AWS Control Tower
40	AWS Trusted Advisor
DEVOPS & CI/CD	
41	AWS CodePipeline
42	Amazon ECR
43	AWS CloudFormation
ANALYTICS	
44	Amazon Athena
45	Amazon Kinesis Data Streams
46	AWS Glue
AI & ML	
47	Amazon Bedrock
48	Amazon Bedrock Guardrails

49	Amazon SageMaker
50	Amazon Comprehend
AGENTIC AI	
51	Amazon Bedrock Agents
52	Amazon Bedrock Knowledge Bases
53	Amazon OpenSearch Service

IDENTITY

Who can do what — IAM, SSO, and organisations

01

AWS IAM

Identity and Access Management — the nervous system of AWS security

IDENTITY

SUMMARY

Controls who can do what across all AWS resources. Manages users, groups, roles, and policies. Central to every AWS security decision.

BUSINESS NEED

Every organisation needs to control access to cloud resources. IAM enables least-privilege access for humans, services, and applications without sharing credentials.

SECURITY IMPACT

Over-permissive IAM is the root cause of the majority of AWS breaches. Wildcard policies, PassRole abuse, and long-lived keys are the top attack vectors.

SECURITY CONFIGURATION

Enforce MFA on all humans. Use roles over users. Scope every policy to specific ARNs. Enable IAM Access Analyzer. Use permission boundaries on developer roles. Deny iam:CreateAccessKey via SCP. Rotate keys via Config rule.

02

AWS IAM Identity Center

Centralised SSO for all AWS accounts and applications

IDENTITY

SUMMARY

Formerly AWS SSO. Provides federated access to multiple AWS accounts and SAML applications from a single identity source (Azure AD, Okta, or built-in directory).

BUSINESS NEED

Enterprises need centralised identity governance across dozens of AWS accounts without managing individual IAM users in every account.

SECURITY IMPACT

Replaces long-lived IAM user access keys with short-lived STS credentials. Eliminates credential sprawl. Provides a single audit trail for all human access.

SECURITY CONFIGURATION

Integrate with corporate IdP (Azure AD/Okta). Enable MFA in Identity Center. Configure permission sets with least-privilege policies. Enable access logs to CloudTrail. Review unused permission sets quarterly.

03

AWS Organizations

Multi-account governance with SCPs as the ultimate guardrail

IDENTITY

SUMMARY

Manages multiple AWS accounts in a hierarchy of Organizational Units (OUs). Applies Service Control Policies (SCPs) as the maximum permission boundary across entire account groups.

BUSINESS NEED

Enterprises run workloads across many accounts for isolation, cost allocation, and compliance. Organizations provides centralised governance over all of them.

SECURITY IMPACT

SCPs are the strongest preventive control in AWS — they override even root. A well-designed SCP baseline eliminates entire classes of misconfiguration across all accounts simultaneously.

SECURITY CONFIGURATION

Deploy deny-list SCP baseline to Root OU: deny CloudTrail disable, GuardDuty delete, root use, outside-region actions. Use OU structure to apply tiered SCPs. Never do production work in the management account.

04

AWS STS

Short-lived temporary credentials — the engine behind all role assumption

IDENTITY

SUMMARY

Security Token Service issues temporary, limited-privilege credentials for IAM roles. Every AssumeRole, federated login, and EC2 instance credential is an STS token.

BUSINESS NEED

Applications and services need AWS credentials at runtime without embedding long-lived keys. STS enables the role-based model that underpins all modern AWS architectures.

SECURITY IMPACT

STS credentials have a limited TTL (15 min to 12 hrs). They cannot be fully revoked before expiry — an attacker with stolen credentials retains access until TTL expires.

SECURITY CONFIGURATION

Set minimum session duration for sensitive roles. Use ExternalId for cross-account roles. Monitor AssumeRole in CloudTrail — flag cross-account assumptions from unexpected accounts. Attach inline deny policy to revoke compromised sessions immediately.

SECURITY

Detect, protect, and respond — the security toolchain

05

AWS GuardDuty

ML-powered threat detection across CloudTrail, VPC, DNS, and ECS

SECURITY

SUMMARY

Continuously analyses CloudTrail logs, VPC Flow Logs, DNS queries, and ECS/EKS runtime for indicators of compromise using threat intelligence and ML anomaly detection.

BUSINESS NEED

Organisations cannot manually analyse billions of API calls and network events. GuardDuty provides automated, always-on threat detection across the entire AWS estate.

SECURITY IMPACT

The primary detection layer for credential compromise, data exfiltration, cryptomining, and lateral movement. Key finding: InstanceCredentialExfiltration.OutsideAWS signals SSRF-to-IMDS attacks.

SECURITY CONFIGURATION

Enable in ALL regions in all accounts via Organizations. Enable ECS/EKS/S3/RDS/Lambda protection add-ons. Auto-archive low-confidence findings. Route high-severity findings to Security Hub and PagerDuty. Never suppress without documented justification.

06

AWS Security Hub

Centralised security posture aggregation across accounts and services

SECURITY

SUMMARY

Aggregates findings from GuardDuty, Inspector, Macie, Config, and third-party tools into a single dashboard. Maps findings to CIS, NIST, PCI-DSS, and AWS FSBP standards.

BUSINESS NEED

Security teams need one pane of glass across hundreds of accounts and dozens of detection services. Security Hub normalises and prioritises findings so analysts know what to fix first.

SECURITY IMPACT

Without aggregation, critical findings get lost in service-specific dashboards. Security Hub provides the compliance baseline score that boards and auditors ask for.

SECURITY CONFIGURATION

Enable CIS AWS Foundations Benchmark v1.4 and AWS FSBP standards. Configure cross-account aggregation to a dedicated Security account. Set up EventBridge rules to auto-ticket HIGH/CRITICAL findings. Review suppression rules monthly.

07

AWS CloudTrail

Immutable API audit trail — the forensic backbone of every incident response

SECURITY

SUMMARY

Records every AWS API call: who, what, when, and from where. Delivers management events, data events, and Insights events to S3 and CloudWatch Logs.

BUSINESS NEED

Compliance frameworks (SOC2, ISO27001, PCI-DSS) require audit trails of all privileged access. CloudTrail is the primary evidence source for every AWS security investigation.

SECURITY IMPACT

Without CloudTrail, you are blind. An attacker's first action post-compromise is often to disable logging. CloudTrail provides the forensic record that makes incident response possible.

SECURITY CONFIGURATION

Enable in all regions. Enable data events for S3 and Lambda. Enable log file validation (SHA256 hash chain). Deliver to a dedicated log archive account. Apply SCP denying StopLogging/DeleteTrail. Enable CloudTrail Lake for SQL-based analysis.

08

AWS KMS

Managed encryption key lifecycle — the root of your encryption hierarchy

SECURITY

SUMMARY

Creates and manages cryptographic keys (CMKs) for encrypting data across all AWS services. Provides envelope encryption: data encrypted with DEKs, DEKs encrypted by CMKs. CMKs never leave the HSM.

BUSINESS NEED

Regulatory frameworks require encryption at rest and control over key lifecycle. KMS provides FIPS 140-2 Level 3 compliant key management without managing physical HSMs.

SECURITY IMPACT

Key policy misconfiguration (Principal:*) exposes encrypted data to any AWS account. Every KMS API call is logged in CloudTrail — providing a decrypt audit trail critical for compliance.

SECURITY CONFIGURATION

Use CMKs over AWS-managed keys for sensitive data — you control key policy and rotation. Never use Principal:* in key policies. Separate CMKs per service/data-classification. Enable automatic annual rotation. Deny KMS key deletion via SCP. Use key grants for cross-account access instead of key policies.

09

AWS WAF

Layer 7 web application firewall protecting APIs and web apps from attacks

SECURITY

SUMMARY

Inspects HTTP/S traffic at Layer 7 against configurable rules. Integrates with CloudFront, ALB, API Gateway, and AppSync. Supports AWS Managed Rule Groups, Bot Control, and custom rules.

BUSINESS NEED

Web applications face constant attack from SQLi, XSS, bad bots, and credential stuffing. WAF provides real-time L7 filtering without changing application code.

SECURITY IMPACT

In agentic AI systems, WAF is the first line of prompt injection defense. Rate-based rules limit DDoS and LLM cost abuse. Without WAF, API Gateway and ALB are directly exposed to web attacks.

SECURITY CONFIGURATION

Enable AWS Managed Rules (Core Rule Set + Known Bad Inputs). Add rate-based rules per IP and per authenticated user. Deploy in COUNT mode first, review false positives, then switch to BLOCK. Integrate with Security Hub for centralised finding management. Log all requests to S3 via Kinesis Firehose.

10

AWS Shield

DDoS protection — Standard free, Advanced for L7 and financial protection

SECURITY

SUMMARY

Shield Standard provides automatic L3/L4 DDoS protection for all AWS resources at no cost. Shield Advanced adds L7 DDoS detection, 24/7 DRT access, cost protection, and attack forensics.

BUSINESS NEED

DDoS attacks can take down revenue-generating services and incur massive bandwidth costs. Shield protects availability and provides financial protection against attack-induced AWS bills.

SECURITY IMPACT

Without Shield Advanced, L7 application-layer DDoS attacks (HTTP floods) bypass Shield Standard. Critical for internet-facing financial, e-commerce, and gaming applications.

SECURITY CONFIGURATION

Enable Shield Advanced for production internet-facing resources (ALB, CloudFront, Route53, EC2 EIP). Configure DDoS response team (DRT) access. Set up proactive engagement. Combine with WAF for L7 protection. Enable cost protection for attack-related overages.

11

AWS Secrets Manager

Centralised secret storage with automatic rotation — eliminates hardcoded credentials

SECURITY

SUMMARY

Stores database credentials, API keys, OAuth tokens, and other secrets. Provides SDK-based runtime retrieval and automatic rotation via Lambda. Integrates with RDS, Redshift, and DocumentDB natively.

BUSINESS NEED

Hardcoded secrets in code or Lambda env vars are the most common source of credential leaks. Secrets Manager removes secrets from application code and enforces rotation.

SECURITY IMPACT

GetSecretValue API calls are logged in CloudTrail. Bulk GetSecretValue from unexpected principals is a key indicator of credential harvesting post-compromise.

SECURITY CONFIGURATION

Enforce encryption with CMK (not default AWS-managed key). Enable automatic rotation for all RDS/Redshift credentials. Grant GetSecretValue via resource-based policy to specific Lambda/ECS task roles only. Alert on GetSecretValue calls from unexpected source IPs. Use resource policies to scope cross-account access.

12

AWS Certificate Manager

Free TLS certificate provisioning and renewal — eliminates expired certificate incidents

SECURITY

SUMMARY

Issues, manages, and auto-renews X.509 TLS certificates for AWS services (ALB, CloudFront, API Gateway). Also supports private CA for internal PKI via ACM Private CA.

BUSINESS NEED

Manual certificate management causes outages from expired certs and introduces risk from weak key management. ACM automates renewal and provides central visibility of certificate inventory.

SECURITY IMPACT

Expired certificates cause service outages and break trust. ACM Private CA is critical for mTLS between microservices and IoT device authentication.

SECURITY CONFIGURATION

Use ACM-issued certificates over self-signed or externally managed wherever possible. Enable certificate transparency logging. Configure CloudWatch alarms for certificates expiring in <30 days for imported certs. Enforce minimum TLS 1.2 on all ALB listeners.

COMPUTE

Virtual machines and the core compute layer

13

Amazon EC2

Virtual machines — the foundation of cloud compute with rich security controls

COMPUTE

SUMMARY

On-demand virtual servers with hundreds of instance types. Supports placement groups, dedicated hosts, Nitro security architecture, and integration with VPC, IAM, and KMS.

BUSINESS NEED

Workloads requiring persistent compute, specific OS configurations, or GPU access run on EC2. Most enterprise lift-and-shift migrations start with EC2.

SECURITY IMPACT

EC2 instances are the primary target for SSRF-to-IMDS attacks. Over-permissive instance roles are frequently the entry point for full account compromise. Exposed SSH/RDP ports lead to brute force or RCE.

SECURITY CONFIGURATION

Enforce IMDSv2 with hop-limit=1 via SCP. Use IAM instance roles (never embed credentials). Encrypt all EBS volumes with CMK. Disable public IPs for non-internet-facing instances. Use Systems Manager Session Manager instead of SSH (no open port 22). Patch via SSM Patch Manager. Restrict security groups to minimum required ports.

SERVERLESS

Event-driven functions with no server management

14

AWS Lambda

Event-driven serverless compute with execution roles and VPC integration

SERVERLESS

SUMMARY

Runs code in response to events (API calls, S3 events, SQS messages) without managing servers. Scales automatically from zero. Supports Python, Node, Java, Go, and custom runtimes.

BUSINESS NEED

Serverless eliminates server management, scales to zero cost when idle, and is the natural compute layer for event-driven architectures, guardrail functions, and tool integrations in agentic systems.

SECURITY IMPACT

Lambda execution roles are prime targets — over-permissive roles combined with GetFunctionConfiguration (exposing env var secrets) lead to multi-service compromise from a single permission.

SECURITY CONFIGURATION

Least-privilege execution role scoped per function. Never store secrets in env vars — use Secrets Manager. Deploy in VPC for access to private resources. Enable X-Ray tracing. Reserve concurrency to prevent noisy-neighbour denial. Enable enhanced monitoring. Use Lambda@Edge only when necessary — separate security review required.

CONTAINER S

Container orchestration and runtime security

15

Amazon ECS

Managed container orchestration with task-level IAM roles and runtime monitoring

CONTAINERS

SUMMARY

Runs Docker containers on EC2 or Fargate. Integrates with ALB, Service Discovery, and CloudMap. Each ECS task gets its own IAM role (task role) for fine-grained access control.

BUSINESS NEED

Containerised microservices require orchestration, service discovery, and load balancing. ECS provides these without the operational complexity of self-managed Kubernetes.

SECURITY IMPACT

ECS task role credentials are accessible at 169.254.170.2 — a malicious container image can steal them at startup. ECR supply chain attacks are the primary vector.

SECURITY CONFIGURATION

Use Fargate over EC2 for reduced attack surface. Enable GuardDuty ECS Runtime Monitoring. Scope task roles to minimum permissions. Enforce ECR image scanning on push. Sign images with AWS Signer. Enable VPC-only ECR endpoints. Use task-level network policies where available.

16

Amazon EKS

Managed Kubernetes with IRSA for pod-level IAM and RBAC enforcement

CONTAINERS

SUMMARY

Managed Kubernetes control plane. Integrates with IAM via OIDC (IRSA — IAM Roles for Service Accounts) so pods get scoped AWS credentials without instance-level IAM. Supports Fargate profiles.

BUSINESS NEED

Organisations standardising on Kubernetes need managed control plane operations with AWS-native integrations for networking, storage, and identity.

SECURITY IMPACT

Misconfigured RBAC allowing broad ClusterAdmin grants, or pods running as root with host network access, enable container escape and cluster-wide compromise. IRSA misconfiguration can leak AWS credentials to all pods.

SECURITY CONFIGURATION

Enable RBAC with least-privilege roles. Use IRSA for all pod AWS access — never use node instance roles. Enable EKS audit logging. Use Calico or AWS network policies for pod-level network segmentation. Enable GuardDuty EKS Runtime Monitoring. Rotate OIDC provider certificates. Enable envelope encryption for etcd secrets.

17

CONTAINERS

AWS Fargate

Serverless containers — no node management, no SSH, reduced attack surface

SUMMARY

Runs ECS/EKS containers without provisioning or managing EC2 nodes. AWS manages the underlying infrastructure. Each task gets dedicated compute with no cross-tenant kernel sharing.

BUSINESS NEED

Removes EC2 patch management, node security hardening, and capacity planning burden. Ideal for teams wanting container orchestration without infrastructure operations.

SECURITY IMPACT

Fargate's single-tenant execution model eliminates cross-container kernel attacks. No SSH access to underlying nodes reduces lateral movement surface significantly.

SECURITY CONFIGURATION

Prefer Fargate over EC2 launch type for security-sensitive workloads. Use Fargate platform version 1.4+ (adds ephemeral storage encryption). Assign task-specific IAM roles. Deploy in private subnets. Enforce ECR image signing. Block public IP assignment via task definition parameter.

NETWORKING

VPC, connectivity, DNS, and edge security

18

NETWORKING

Amazon VPC

Isolated virtual network with subnets, route tables, and security groups

SUMMARY

Logically isolated network within AWS. Contains public and private subnets across multiple AZs. Controls traffic with Security Groups (stateful, instance-level) and NACLs (stateless, subnet-level).

BUSINESS NEED

Network isolation is the foundation of cloud security architecture. VPC enables separation of tiers (web, app, data), private connectivity to AWS services, and enforcement of data residency.

SECURITY IMPACT

Misconfigured security groups (0.0.0.0/0 on port 22/3389/3306) are the most common direct exposure risk. VPC peering without proper routing controls creates unintended cross-account access.

SECURITY CONFIGURATION

Three-tier subnet model: public (ALB/NAT), private app (compute), private data (DB — no default route). Enable VPC Flow Logs to S3. Use VPC endpoints for all AWS service access from private subnets. No 0.0.0.0/0 on security groups for databases. Use AWS Network Firewall for stateful deep packet inspection between VPCs.

19

NETWORKING

AWS PrivateLink

Private connectivity to AWS services without internet traversal

SUMMARY

Creates private endpoints (ENIs with private IPs) in your VPC for AWS services and third-party SaaS. Traffic stays on the AWS network — never traverses the internet or requires NAT.

BUSINESS NEED

Compliance requirements often mandate that data never traverse public networks. PrivateLink provides private connectivity to S3, Bedrock, Secrets Manager, and partner services.

SECURITY IMPACT

Without PrivateLink, private subnet resources must use NAT Gateway for AWS service access — creating an internet egress path. PrivateLink eliminates this and enables data exfiltration prevention via endpoint policies.

SECURITY CONFIGURATION

Deploy interface endpoints for: Bedrock, STS, KMS, Secrets Manager, SSM, ECR, CloudWatch, S3. Configure S3 gateway endpoint (free). Apply endpoint policies restricting S3 access to org-owned buckets only (aws:ResourceOrgID condition). Disable private DNS override where not needed.

20

Amazon Route 53

Scalable DNS with health-based routing and DNSSEC signing

NETWORK
KING

SUMMARY

Authoritative DNS service with health checking, traffic routing policies (latency, weighted, geolocation, failover), and DNSSEC support. Also provides private hosted zones for internal DNS.

BUSINESS NEED

DNS is the phonebook of the internet — availability, performance, and correctness of DNS directly impacts application availability and user experience.

SECURITY IMPACT

DNS hijacking can redirect users to attacker-controlled infrastructure. Without DNSSEC, attackers can poison DNS caches. Route 53 Resolver query logs provide visibility into internal DNS lookups that can indicate C2 communication.

SECURITY CONFIGURATION

Enable DNSSEC signing for public hosted zones. Enable Route 53 Resolver Query Logs — feeds into GuardDuty DNS threat detection. Use private hosted zones for internal service discovery. Restrict Route 53 API access to infrastructure-as-code roles. Enable domain transfer lock on registered domains.

21

AWS CloudFront

Global CDN and edge security layer — first stop for internet traffic

NETWORK
KING

SUMMARY

Global content delivery network with 450+ edge locations. Caches static content, terminates TLS at the edge, and integrates with WAF, Shield, and Lambda@Edge for edge compute.

BUSINESS NEED

Reduces latency for global users, absorbs DDoS traffic at the edge, offloads origin servers, and provides a consistent TLS termination point for all public-facing applications.

SECURITY IMPACT

CloudFront is the first security boundary for internet traffic. Misconfigured origin access allows direct S3 bucket access bypassing CloudFront security policies. Without OAC, S3 origins can be accessed publicly.

SECURITY CONFIGURATION

Use Origin Access Control (OAC) for S3 origins — not legacy OAI. Enforce HTTPS only (redirect HTTP). Set minimum TLS 1.2. Enable WAF association. Disable HTTP on all behaviours. Use signed URLs/cookies for private content. Enable real-time logging to Kinesis. Restrict viewer protocol policy to HTTPS only.

22

NETWORK
KING

AWS Direct Connect

Dedicated private fibre connection between on-premises and AWS

SUMMARY

Provides a dedicated, private network connection from on-premises data centres to AWS. Bypasses the public internet with consistent bandwidth and reduced latency.

BUSINESS NEED

Enterprises migrating workloads or running hybrid architectures need reliable, low-latency connectivity with predictable bandwidth and cost for large data transfers.

SECURITY IMPACT

Direct Connect connections are not encrypted by default. A physical compromise of the colocation or last-mile circuit would expose unencrypted traffic. Also a potential exfiltration path if not monitored.

SECURITY CONFIGURATION

Always run MACsec (Layer 2 encryption) or IPSec VPN over Direct Connect for encryption in transit. Restrict BGP peer IPs. Monitor advertised routes — unexpected prefixes indicate misconfiguration or compromise. Use separate connections for different security zones. Enable CloudWatch metrics for connection monitoring.

STORAGE

Object, block, and file storage security

23

Amazon S3

Object storage — the most common source of data exposure in AWS

STORAGE

SUMMARY

Virtually unlimited object storage with 99.999999999% durability. Supports versioning, lifecycle policies, cross-region replication, event notifications, and server-side encryption.

BUSINESS NEED

S3 stores everything: application data, backups, ML training data, audit logs, static website assets. It is the default destination for almost every AWS service's output.

SECURITY IMPACT

Misconfigured public access is responsible for the majority of AWS data breaches. A single public bucket containing .env files, Terraform state, or database dumps can lead to full account compromise.

SECURITY CONFIGURATION

Enable Block Public Access at the account level. Enforce SSE-KMS with CMK for sensitive buckets. Enable versioning and Object Lock for log buckets. Configure S3 server access logging. Use bucket policies with aws:PrincipalOrgID condition. Enable Macie for PII detection. SCP: deny PutBucketAcl with public-read ACL.

24

Amazon EBS

Block storage for EC2 — encrypted volumes prevent data recovery post-termination

STORAGE

SUMMARY

Persistent block storage for EC2 instances. Supports SSD (gp3, io2) and HDD (st1, sc1) types. Snapshots stored in S3 with point-in-time recovery and cross-region copy.

BUSINESS NEED

Stateful applications (databases, file servers, analytics workloads) require persistent block storage that survives instance restarts and supports high IOPS.

SECURITY IMPACT

Unencrypted EBS volumes and snapshots can be copied to another account and mounted to read raw data. Public EBS snapshots are a frequent source of unintentional data exposure.

SECURITY CONFIGURATION

Enable EBS encryption by default at the account level (aws ec2 enable-ebs-encryption-by-default). Use CMK for encryption. Audit public snapshots monthly via Config rule ec2-ebs-snapshot-public-restorable-check. SCP: deny ec2:CreateVolume without ec2:Encrypted condition set to true. Automate snapshot deletion via lifecycle policies.

25

Amazon EFS

Scalable shared file system with IAM and NFS-level access controls

STORAGE

SUMMARY

Managed NFS-compatible file system that scales automatically. Supports multiple concurrent EC2 mounts. Provides encryption in transit (TLS) and at rest (KMS). Integrates with Lambda and ECS.

BUSINESS NEED

Shared file systems are needed for lift-and-shift NFS workloads, shared content stores for web servers, and ML training data accessible from multiple compute nodes.

SECURITY IMPACT

Without EFS resource policies and IAM auth, any EC2 in the VPC can mount the file system. NFS traffic without TLS is cleartext — VPC network access = data access.

SECURITY CONFIGURATION

Enable encryption at rest (KMS CMK) and in transit (mount with TLS). Configure EFS resource policy restricting mount to specific IAM roles or VPC endpoints. Use access points for application-level path isolation. Disable anonymous access. Monitor mount targets — each creates an ENI that should be reviewed.

26

AWS Backup

Centralised backup with compliance policies and cross-account vault isolation

STORAGE

SUMMARY

Centralised backup service for EC2, EBS, RDS, DynamoDB, EFS, S3, and more. Supports backup plans, retention policies, cross-region/cross-account copy, and immutable vault lock.

BUSINESS NEED

Ransomware attacks and accidental deletion require reliable, isolated backups. Backup provides centralised policy management and compliance reporting for all backup activities.

SECURITY IMPACT

Backups stored in the same account as production data can be deleted by ransomware alongside primary data. Cross-account vaults in a separate backup account with vault lock provide true air-gap protection.

SECURITY CONFIGURATION

Store backups in a dedicated backup account with AWS Backup Vault Lock (COMPLIANCE mode). Enable cross-region backup for DR. Use SCP to deny backup deletion in production accounts. Encrypt vaults with CMK. Test restore procedures quarterly. Enable backup audit reports to S3 for compliance evidence.

DATABASE

Relational and NoSQL database security controls

27

Amazon RDS

Managed relational databases with encryption, IAM auth, and automated patching

DATABASE

SUMMARY

Managed relational database service supporting MySQL, PostgreSQL, Oracle, SQL Server, and MariaDB. Handles patching, backups, Multi-AZ failover, and read replicas automatically.

BUSINESS NEED

Relational databases are the backbone of most enterprise applications. RDS removes database administration burden while maintaining compatibility with existing SQL applications.

SECURITY IMPACT

RDS instances exposed to the internet with weak passwords are among the most commonly exploited cloud resources. Unencrypted database snapshots shared publicly expose all customer data.

SECURITY CONFIGURATION

Deploy in private subnets only — no public accessibility. Enable encryption at rest (CMK) and in transit (enforce SSL via parameter group). Use IAM database authentication (no passwords). Enable Enhanced Monitoring and Performance Insights. Restrict security group to app-tier SG only. Enable automated backups with 35-day retention. Audit RDS event subscriptions.

28

Amazon DynamoDB

Serverless NoSQL with fine-grained IAM and point-in-time recovery

DATABASE

SUMMARY

Fully managed key-value and document database with single-digit millisecond performance at any scale. Supports global tables, streams, DAX caching, and point-in-time recovery (PITR).

BUSINESS NEED

Applications requiring millisecond latency at massive scale (gaming, IoT, session stores, leaderboards) benefit from DynamoDB's automatic scaling and global replication.

SECURITY IMPACT

Overly permissive IAM policies granting dynamodb:* allow full table reads — a single compromised Lambda with broad DynamoDB access exposes all application data. Resource-based policies with Principal:* expose tables externally.

SECURITY CONFIGURATION

Enable encryption at rest (CMK). Enable PITR (35-day recovery). Use fine-grained IAM conditions (dynamodb:LeadingKeys) to restrict access per user. Enable DynamoDB Streams for audit trail. Apply resource policy restricting cross-account access. Monitor for table deletion via CloudTrail alerts. Never grant dynamodb:* — scope to specific tables and operations.

29

DATABASE

Amazon ElastiCache

In-memory caching with Redis auth, TLS, and VPC isolation for session stores

SUMMARY

Managed Redis and Memcached clusters for sub-millisecond data access. Used for session stores, query caching, leaderboards, and agent short-term memory in AI architectures.

BUSINESS NEED

Caching reduces database load and improves application response times. In agentic AI systems, Redis is the canonical short-term memory store for multi-turn conversations.

SECURITY IMPACT

Redis without AUTH token or TLS is accessible to any host in the VPC. In-memory session data includes authentication tokens — a compromised Redis exposes all active user sessions.

SECURITY CONFIGURATION

Always enable Redis AUTH token. Enable in-transit and at-rest encryption. Deploy in private subnet — no public access. Restrict security group to app-tier SG only. Use Redis ACL (Redis 6+) for fine-grained command-level access control. Enable automatic failover. Monitor cache hit rate — drops may indicate attack or misconfiguration.

30

DATABASE

Amazon Aurora

MySQL/PostgreSQL-compatible cloud-native database with Serverless v2 scaling

SUMMARY

AWS-designed relational database offering 5x MySQL and 3x PostgreSQL performance. Supports Aurora Serverless v2 for automatic scaling, Global Database for multi-region DR, and zero-downtime patching.

BUSINESS NEED

High-performance transactional workloads requiring relational semantics with cloud-native scaling and global availability choose Aurora over standard RDS engine options.

SECURITY IMPACT

Aurora's shared storage architecture means a compromised database user with sufficient privileges can read all data across the cluster. Aurora Serverless has reduced network isolation controls.

SECURITY CONFIGURATION

Enable IAM database authentication. Enforce SSL connections via cluster parameter. Use Aurora DB Activity Streams for real-time audit trail to Kinesis (required for PCI-DSS). Enable encryption with CMK. Restrict master user credentials — use individual IAM users per application. Private subnets only. Enable automated backups and PITR.

MESSAGING

Queuing, pub/sub, and event routing

31

Amazon SQS

Managed message queuing — decouples services and absorbs traffic spikes

MESSAGING

SUMMARY

Fully managed message queue supporting standard (at-least-once) and FIFO (exactly-once) queues. Decouples producers and consumers, enabling async processing with dead-letter queues for error handling.

BUSINESS NEED

Async processing of jobs (orders, notifications, ML inference requests) requires reliable queuing that handles spikes without losing messages or overwhelming downstream services.

SECURITY IMPACT

SQS queue policies with Principal:* allow any AWS account to send or receive messages — enabling cross-account data injection or exfiltration. Unencrypted queues expose message content to AWS infrastructure.

SECURITY CONFIGURATION

Enable SSE with KMS CMK. Restrict queue policy to specific AWS account and IAM role. Enable dead-letter queue for poison-message detection. Enable server-side encryption. Do not use Principal:* in resource policy. Configure CloudWatch alarms on ApproximateNumberOfMessagesNotVisible for queue depth anomalies. Use VPC endpoints for private subnet access.

32

Amazon SNS

Pub/sub messaging for fan-out event distribution and security alerting

MESSAGING

SUMMARY

Managed publish-subscribe service. Topics fan out messages to SQS, Lambda, HTTP endpoints, email, and SMS simultaneously. Integrates with CloudWatch Alarms and EventBridge for alerting.

BUSINESS NEED

Security alerting architectures use SNS to fan out critical findings to multiple channels (PagerDuty, Slack, ticketing systems) simultaneously. Also used for application event distribution.

SECURITY IMPACT

SNS topics with no access policy are private by default but cross-account subscriptions without validation allow external parties to subscribe to internal event streams.

SECURITY CONFIGURATION

Enable SSE with KMS CMK. Restrict topic policy — require HTTPS for all deliveries. Enable delivery status logging for compliance. Validate subscription endpoints before publishing sensitive data. Use SNS filter policies to route only appropriate events to each subscriber. Apply resource policies limiting who can publish.

33

MESSAGING

Amazon EventBridge

Serverless event bus — the glue for security automation and service integration

SUMMARY

Serverless event router that connects AWS services, SaaS applications, and custom applications. Rules match events and route to Lambda, SQS, Step Functions, and other targets. Supports scheduled rules (cron).

BUSINESS NEED

Security automation (auto-remediation of Config findings, GuardDuty-triggered responses, IAM key rotation) runs on EventBridge rules. Also the integration layer for event-driven microservice architectures.

SECURITY IMPACT

EventBridge rules triggered by GuardDuty or Security Hub findings can auto-remediate security issues. Misconfigured rules or broad event patterns can trigger unintended actions on production resources.

SECURITY CONFIGURATION

Scope event patterns to specific source services and detail types. Use DLQs on all rules for failed delivery visibility. Encrypt event archives with KMS CMK. Restrict cross-account event bus access via resource policy. Audit all rules quarterly — remove unused rules. Tag rules to track purpose and owner.

MONITORING

Metrics, logs, tracing, and compliance

34

Amazon CloudWatch

Metrics, logs, and alarms — the observability backbone with security alerting

MONITORING

SUMMARY

Collects metrics, logs, and events from all AWS services. Supports custom metrics, log insights queries, composite alarms, and dashboards. CloudWatch Logs Insights provides SQL-like log analysis.

BUSINESS NEED

Applications and infrastructure require monitoring for performance, availability, and security anomalies. CloudWatch centralises all telemetry with alerting that drives operational and security response.

SECURITY IMPACT

CloudWatch Logs stores Lambda execution logs, VPC Flow Logs, and application logs — often containing sensitive data. Log group encryption is disabled by default. Overly permissive log group policies expose application internals.

SECURITY CONFIGURATION

Encrypt all log groups with KMS CMK. Set retention policies (never unlimited). Enable metric filters for security events (root login, failed auth, console sign-in without MFA). Set alarm on failed console logins. Restrict CloudWatch Logs access via IAM. Export security-relevant logs to S3 for long-term retention and SIEM ingestion.

35

AWS Config

Continuous compliance monitoring — tracks configuration drift and evaluates rules

MONITORING

SUMMARY

Records configuration state of all AWS resources and evaluates against compliance rules. Provides configuration history, change notifications, and conformance packs (collections of rules).

BUSINESS NEED

Continuous compliance requires knowing when resources deviate from desired state. Config provides the configuration history needed for audit evidence and auto-remediation of drift.

SECURITY IMPACT

Config is the compliance layer that catches misconfigurations that IAM policy cannot prevent. Without Config, you rely on manual audits to detect security drift. Config findings feed Security Hub.

SECURITY CONFIGURATION

Enable in all regions and all accounts via AWS Organizations. Deploy CIS Benchmark conformance pack. Configure auto-remediation with SSM Automation for high-confidence rules. Enable Config aggregation to a dedicated security account. Alert on Config recorder being stopped (SCP should also prevent this). Review non-compliant resources daily.

36

AWS CloudWatch Synthetics

Canary monitoring for endpoint availability and certificate expiry detection

MONITORING

SUMMARY

Creates canary scripts that simulate user interactions with APIs and web UIs. Monitors endpoint availability, response times, and certificate validity from multiple regions.

BUSINESS NEED

Proactive monitoring catches service degradation and certificate expiry before users are impacted. Security-relevant: detects content injection or response manipulation by comparing baseline to current.

SECURITY IMPACT

Expired TLS certificates cause service outages and break trust. Canaries that monitor authentication endpoints can detect session fixation or login page defacement.

SECURITY CONFIGURATION

Create canaries for all production API endpoints and login flows. Store canary artifacts (screenshots, HAR files) in S3 with SSE-KMS. Restrict canary execution role to minimum S3 and CloudWatch permissions. Set alarms on canary success rate below threshold. Monitor certificate expiry canaries with 30-day warning.

37

AWS X-Ray

Distributed tracing for microservices — finds latency and identifies anomalous calls

MONITORING

SUMMARY

Distributed tracing service that maps service-to-service calls, measures latency at each hop, and identifies errors. Supports sampling rules to control trace volume and cost.

BUSINESS NEED

Microservice architectures make it hard to diagnose performance issues or identify which service is causing errors. X-Ray provides end-to-end request visibility across Lambda, ECS, API Gateway, and more.

SECURITY IMPACT

X-Ray traces can expose internal service architectures, database schemas, and sensitive parameter values if trace data is not carefully filtered. Trace data is stored in X-Ray and accessible via IAM.

SECURITY CONFIGURATION

Enable X-Ray for all Lambda functions and ECS services. Use sampling rules to balance coverage and cost. Filter sensitive data from trace annotations. Restrict `xray:GetTraceSummaries` and `xray:BatchGetTraces` to security/observability roles. Set trace data retention to match compliance requirements.

GOVERNANCE

Policy, posture management, and best practices

38

AWS IAM Access Analyzer

Continuous external access detection and least-privilege policy generation

GOVERNANCE

SUMMARY

Analyses resource-based policies, trust policies, and IAM policies to identify external access findings. Generates least-privilege policy recommendations based on actual CloudTrail activity. Validates policies before deployment.

BUSINESS NEED

Security teams cannot manually review all IAM policies and resource policies across hundreds of accounts. Access Analyzer automates external access detection and policy right-sizing.

SECURITY IMPACT

Finds S3 buckets, KMS keys, Lambda functions, and IAM roles accessible outside your account or org — often revealing misconfigurations that have existed for months without detection.

SECURITY CONFIGURATION

Enable in every account and every region via AWS Organizations. Create organisation-level analyser (covers all accounts). Review all findings within 30 days — archive only with documented justification. Integrate findings into Security Hub. Use policy validation before deploying any new IAM policy. Set up EventBridge rule to alert on new external access findings within 1 hour.

39

AWS Control Tower

Landing zone automation — account vending with built-in security guardrails

GOVERNANCE

SUMMARY

Orchestrates the setup of a multi-account AWS environment (landing zone) with pre-configured OUs, SCPs, AWS Config rules, and CloudTrail. Automates new account provisioning with security guardrails.

BUSINESS NEED

Building a secure multi-account environment from scratch requires significant expertise and time. Control Tower provides a proven baseline that implements AWS Well-Architected security best practices automatically.

SECURITY IMPACT

Control Tower guardrails (strongly recommended + elective) enforce SCP-based controls across all accounts. Without a landing zone, individual teams create accounts without security baselines.

SECURITY CONFIGURATION

Deploy proactive and detective guardrails appropriate for your industry. Customise with CfCT (Customisations for Control Tower) for org-specific controls. Integrate with IAM Identity Center. Enable Control Tower drift detection. Review landing zone health monthly in Control Tower dashboard.

40

GOVERNANCE

AWS Trusted Advisor

Automated best-practice checks across cost, performance, security, and fault tolerance

SUMMARY

Inspects your AWS environment and provides recommendations across 5 pillars: cost, performance, security, fault tolerance, and service limits. Business/Enterprise support includes all checks.

BUSINESS NEED

Ongoing identification of security misconfigurations, underutilised resources, and service limit risks requires systematic scanning. Trusted Advisor provides this as a managed service.

SECURITY IMPACT

Security checks include: open security groups, IAM use, MFA on root, S3 bucket permissions, and exposed access keys. Trusted Advisor exposed keys check notifies within hours of a GitHub leak.

SECURITY CONFIGURATION

Enable all security checks (requires Business or Enterprise support). Configure Trusted Advisor integration with Security Hub. Set up SNS notifications for security check failures. Review security-specific checks weekly. Use the exposed access keys check as an early warning — treat any alert as P0.

DEVOPS & CI/CD

Pipeline security and artifact integrity

41

AWS CodePipeline

Continuous delivery pipeline with IAM role-based stage execution

DEVOPS
& CI/CD

SUMMARY

Fully managed CI/CD pipeline that orchestrates build, test, and deploy stages. Integrates with CodeBuild, CodeDeploy, CloudFormation, and third-party tools (GitHub, Jenkins, Artifactory).

BUSINESS NEED

Automated, repeatable deployments with approval gates reduce human error, enforce separation of duties, and provide an audit trail of every change to production.

SECURITY IMPACT

Pipeline execution roles are often over-privileged — a compromised pipeline can deploy malicious code to production. OIDC misconfigurations in GitHub Actions allow any PR to assume the deployment role.

SECURITY CONFIGURATION

Least-privilege pipeline execution role — separate roles per stage. Require manual approval for production deployments. Use OIDC for GitHub Actions with branch conditions on token:sub. Sign artifacts with AWS Signer. Enable pipeline execution history in CloudTrail. Restrict who can edit pipeline definitions to infrastructure-as-code roles only.

42

Amazon ECR

Private container registry with vulnerability scanning and image signing

DEVOPS
& CI/CD

SUMMARY

Fully managed Docker container registry. Stores, manages, and deploys container images. Supports image scanning (basic and enhanced via Inspector), lifecycle policies, and replication.

BUSINESS NEED

Container-based deployments need a secure, private registry to store and version images. ECR integrates natively with ECS, EKS, and CodePipeline for seamless CI/CD workflows.

SECURITY IMPACT

ECR is a critical supply chain control point. A malicious image in ECR that gets deployed to ECS/EKS runs in production with the task role's permissions. Public ECR repositories can expose proprietary code.

SECURITY CONFIGURATION

Enable enhanced scanning (Inspector) on all repositories. Create a deployment gate: block if Critical CVEs found. Sign images with AWS Signer — enforce signature verification in ECS/EKS task definitions. Enable lifecycle policies to delete untagged images. Set repository policies restricting cross-account pull. Scan on push AND on schedule (new CVEs emerge daily).

43

DEVOPS
& CI/CD

AWS CloudFormation

Infrastructure as code with stack policies and drift detection

SUMMARY

Declarative IaC service that provisions and manages AWS resources from JSON/YAML templates. Supports StackSets for multi-account/region deployment, drift detection, and change sets for preview.

BUSINESS NEED

Infrastructure reproducibility, version control, and automated provisioning require IaC. CloudFormation is the native AWS IaC tool with deepest service integration and no additional tooling required.

SECURITY IMPACT

CloudFormation execution roles are often highly privileged. A compromised template source (S3 bucket) or template injection can provision malicious resources. StackSets with admin delegation create powerful cross-account roles.

SECURITY CONFIGURATION

Use service roles (not user credentials) for stack operations. Store templates in S3 with versioning and object lock. Apply stack policies to prevent destructive updates on production stacks. Enable drift detection and alert on drift. Restrict who can update StackSets. Review all CAPABILITY_IAM and CAPABILITY_NAMED_IAM usages.

ANALYTICS

Data processing and security log analysis

44

Amazon Athena

Serverless SQL queries over S3 — security log analysis without infrastructure

ANALYTICS

SUMMARY

Interactive query service using standard SQL to analyse data in S3. Serverless — no infrastructure to manage. Used for CloudTrail Lake queries, VPC Flow Log analysis, and security investigations.

BUSINESS NEED

Security teams need to query terabytes of CloudTrail and VPC Flow Logs for incident investigation. Athena provides ad-hoc SQL queries over S3 data without loading into a database.

SECURITY IMPACT

Athena queries can access any S3 data the execution role has permission to read. Overly broad Athena execution roles can be used to exfiltrate sensitive S3 data via SELECT statements.

SECURITY CONFIGURATION

Restrict Athena execution role to specific S3 prefixes (CloudTrail/VPC logs buckets). Encrypt query results with KMS CMK in S3. Enable workgroup configuration to enforce encryption and query limits. Log all Athena queries via CloudTrail. Use named queries for standard security investigation playbooks.

45

Amazon Kinesis Data Streams

Real-time data streaming for security event pipelines and log ingestion

ANALYTICS

SUMMARY

Managed real-time data streaming for ingesting and processing large volumes of data. Used as the backbone for security event pipelines: WAF logs, VPC Flow Logs, and GuardDuty findings to SIEM.

BUSINESS NEED

Real-time security monitoring requires streaming ingestion of events at high throughput. Kinesis provides the reliable, ordered event pipeline between AWS security services and SIEM/SOAR tools.

SECURITY IMPACT

Kinesis streams without server-side encryption expose security event data in transit. A compromised consumer with broad GetRecords permissions can read the entire security event stream.

SECURITY CONFIGURATION

Enable server-side encryption with KMS CMK. Restrict PutRecord/GetRecords to specific producer/consumer roles. Enable enhanced fan-out for dedicated throughput per consumer. Monitor iterator age — high values indicate consumer lag. Set up DLQ for failed record processing. Enable CloudWatch metrics for all streams.

46

ANALYTICS

AWS Glue

Serverless ETL with data catalog and column-level security for analytics pipelines

SUMMARY

Serverless data integration service for ETL jobs. Includes a Data Catalog (metadata repository), crawlers, and Glue Studio for visual job building. Supports Lake Formation for fine-grained data access.

BUSINESS NEED

Data warehousing and ML pipelines require ETL processing of raw data. Glue provides managed Spark-based transformation without managing clusters.

SECURITY IMPACT

Glue development endpoints (Jupyter notebooks) accept PassRole — a misconfigured Glue dev endpoint with an admin role is a full admin RCE surface. Often overlooked in IAM reviews.

SECURITY CONFIGURATION

Deny `glue:CreateDevEndpoint` via SCP in production accounts. Scope Glue job IAM roles to minimum S3 prefixes. Encrypt Glue Data Catalog with KMS CMK. Use Lake Formation for column/row-level security on sensitive datasets. Never grant broad S3 access to Glue roles — use resource-based policies with specific bucket/prefix.

AI & ML

Foundation models, NLP, and ML platform security

47

Amazon Bedrock

Managed foundation model API — the core LLM runtime for AI applications

AI & ML

SUMMARY

Serverless API access to foundation models (Claude, Titan, Llama, Mistral, Stability AI). Provides model invocation, fine-tuning, RAG via Knowledge Bases, and agentic workflows via Bedrock Agents.

BUSINESS NEED

Organisations building AI features need access to state-of-the-art models without training or hosting infrastructure. Bedrock provides managed model access with enterprise security controls.

SECURITY IMPACT

Bedrock is the LLM execution boundary. Every prompt and response can contain sensitive customer data, PII, or confidential business information. Model invocation logs are critical for compliance in regulated industries.

SECURITY CONFIGURATION

Enable model invocation logging to CloudWatch/S3 — required for compliance in regulated industries. Apply Bedrock Guardrails for input/output filtering. Use VPC interface endpoints to keep traffic private. Scope Bedrock IAM permissions to specific model ARNs. Enable Bedrock access logging and integrate with Security Hub.

48

Amazon Bedrock Guardrails

AI-native safety layer — semantic content filtering beyond WAF keyword rules

AI & ML

SUMMARY

Applies to every Bedrock model invocation: denied topic blocking, content filters (hate/violence/sexual/PROMPT_ATTACK), PII detection/anonymisation, grounding checks, and word blocklists. Works on both input and output.

BUSINESS NEED

AI applications in regulated industries (banking, healthcare) need controls that prevent the model from providing harmful advice, leaking PII, or generating inappropriate content. Guardrails provide these natively.

SECURITY IMPACT

Unlike WAF which matches HTTP patterns, Guardrails understands semantic meaning — catches multi-language injection, contextual jailbreaks, and hallucinated PII that keyword rules miss. The grounding check is the only control that detects hallucination against RAG source documents.

SECURITY CONFIGURATION

Configure denied topics with natural-language definitions and examples. Set content filters to HIGH for HATE, SEXUAL, PROMPT_ATTACK. Enable PII policy with ANONYMIZE for email/phone, BLOCK for SSN/card numbers. Set grounding threshold 0.75+ for regulated advice scenarios. Attach to every Bedrock Agent and direct model invocation.

49

Amazon SageMaker

Full ML lifecycle management with VPC isolation and model monitoring

AI & ML

SUMMARY

End-to-end ML platform: data preparation, model training, hyperparameter tuning, deployment, and monitoring. Supports Jupyter notebooks, training clusters, inference endpoints, and MLOps pipelines.

BUSINESS NEED

Data science teams need a managed platform for the entire ML lifecycle from experimentation to production deployment with reproducibility, collaboration, and scalability.

SECURITY IMPACT

SageMaker Studio notebooks running in default internet mode can exfiltrate training data or models. Notebook execution roles are frequently over-privileged. Training jobs access S3 data — role scope is critical.

SECURITY CONFIGURATION

Enable SageMaker Studio in VPC-only mode. Disable internet access for notebooks and training jobs. Use CMK encryption for all SageMaker storage. Apply least-privilege execution role per notebook user (use IAM Identity Center). Enable SageMaker Model Monitor for data drift and bias. Restrict model deployment to approved model registry entries only.

50

Amazon Comprehend

NLP service for PII detection and text classification in security pipelines

AI & ML

SUMMARY

Managed NLP service for entity recognition (PII, organisations, locations), sentiment analysis, topic modelling, and custom classification. Used in security pipelines to scrub PII before sending text to LLMs.

BUSINESS NEED

Agentic AI systems, customer-facing chatbots, and data processing pipelines need to detect and redact PII in user input before it reaches the LLM, is logged, or stored in vector databases.

SECURITY IMPACT

Without Comprehend (or equivalent) PII scrubbing, customer data (Aadhaar, credit cards, phone numbers) entered into an AI chatbot gets stored in CloudWatch logs, DynamoDB memory stores, and OpenSearch vectors — creating compliance violations.

SECURITY CONFIGURATION

Run as an input guardrail Lambda before forwarding to Bedrock. Confidence threshold 0.85 for scrubbing (tune based on false positive rate). Replace detected PII with typed placeholders [NAME], [PHONE]. Log PII type counts (not values) for compliance metrics. Use Comprehend Custom Entity Recognition for domain-specific identifiers (account numbers, policy IDs).

AGENTIC AI

Orchestration, RAG, and vector store security

51

Amazon Bedrock Agents

Fully managed agentic orchestrator with ReAct reasoning and tool calling

AGENTIC
AI

SUMMARY

Managed agentic runtime that orchestrates multi-step LLM reasoning (plan-execute-observe loop). Manages Action Groups (tool calling), Knowledge Bases (RAG), session state, and guardrail application per invocation.

BUSINESS NEED

Building agentic AI applications requires a reliable orchestration layer that handles tool calling, memory management, session state, and safety controls. Bedrock Agents provides this as a managed service.

SECURITY IMPACT

Bedrock Agents have execution roles that can call AWS services via Action Groups. A prompt injection attack that hijacks the agent's reasoning can cause it to call tools with malicious parameters — deleting data, initiating transfers, or exfiltrating information.

SECURITY CONFIGURATION

Apply least-privilege execution role to the Bedrock Agent — scope to only the Action Groups it needs. Attach Bedrock Guardrails with PROMPT_ATTACK filter at HIGH. Enable model invocation logging. Use human-in-the-loop for irreversible actions (financial transactions, data deletion). Validate all Action Group Lambda inputs — never trust agent-provided parameters without validation.

52

Amazon Bedrock Knowledge Bases

Managed RAG pipeline with vector store, embedding, and semantic retrieval

AGENTIC
AI

SUMMARY

End-to-end managed RAG (Retrieval-Augmented Generation) pipeline. Ingests documents from S3, generates embeddings, stores in a vector database (OpenSearch Serverless or Aurora pgvector), and provides semantic retrieval at query time.

BUSINESS NEED

AI agents and assistants need to answer questions grounded in enterprise knowledge (SOPs, policies, product documentation) without hallucinating. Knowledge Bases provides this grounding without fine-tuning.

SECURITY IMPACT

The knowledge base is a new attack surface: prompt injection embedded in ingested documents (data-plane prompt injection) can hijack agent behaviour when retrieved. Sensitive documents in the knowledge base may be surfaced to unauthorised users if retrieval is not scoped.

SECURITY CONFIGURATION

Apply access control on the S3 source bucket. Encrypt vector store (OpenSearch) with CMK. Validate all documents before ingestion — scan for embedded prompt injection patterns. Use metadata filtering to restrict retrieval per user role. Enable OpenSearch access policies to prevent cross-tenant retrieval. Monitor retrieved chunk contents for sensitive data patterns.

53 AGENTIC AI Amazon OpenSearch Service Search and vector database for RAG, log analytics, and SIEM use cases	
SUMMARY Managed OpenSearch and Elasticsearch compatible service. Used for full-text search, log analytics, and as a vector store for AI Knowledge Bases. OpenSearch Serverless provides auto-scaling without capacity management.	BUSINESS NEED Security teams use OpenSearch as a SIEM backend for CloudTrail, VPC Flow Logs, and WAF logs. AI architects use it as the vector store for RAG pipelines requiring semantic search over enterprise data.
SECURITY IMPACT OpenSearch clusters with public endpoints and weak access policies are a common data exposure risk. In RAG architectures, compromising the vector store means an attacker can inject false context into every agent response (data poisoning).	SECURITY CONFIGURATION Deploy in VPC — disable public endpoint. Enable fine-grained access control (FGAC) with IAM and SAML. Encrypt at rest with CMK and in transit with TLS. Enable Audit Logging for all index operations. For RAG use cases: apply index-level access policies per tenant. Enable domain-level anomaly detection. Restrict master user to a break-glass role.

Quick Reference — Security Priority Matrix

The 10 services where a single misconfiguration most commonly leads to account compromise or data breach:

#	Service	Why it is the highest-priority misconfiguration to prevent
01	IAM	PassRole + RunInstances = admin credentials via IMDS. Wildcard policies = instant admin.
03	AWS Organizations	No SCPs = no floor. A compromised account can disable all detection and erase its trail.
05	GuardDuty	Disabled GuardDuty = blind threat detection. Always enable in all regions via Org delegation.
07	CloudTrail	Disabled CloudTrail = no forensic record. An attacker's first move post-compromise.
08	KMS	Principal:* on key policy = any account can decrypt. Zero-cost change, maximum damage.
11	Secrets Manager	Not used = secrets in Lambda env vars = bulk theft via GetFunctionConfiguration.
13	EC2	IMDSv1 + SSRF = admin credentials stolen in seconds. Enforce IMDSv2 via SCP.
23	S3	Public bucket = data breach. Block Public Access at account level. Most common breach vector.
47	Bedrock	No Guardrails = prompt injection hijacks agents. No invocation logging = no compliance evidence.
51	Bedrock Agents	Overpermissive Action Group role + no HITL = attacker controls production actions via prompt.

As a Security Architect, think in blast radius: for every service, ask 'what is the worst-case impact if this service is misconfigured or compromised?' Design controls to the worst case, not the average case.